

Data Protection Policy

Langate Group

Purpose

This policy outlines the procedures and technical controls for data protection at Langate Group.

Scope

This policy applies to all production systems that create, receive, store, or transmit Langate Group customer data (hereafter "Production Systems").

Roles and Responsibilities

- **IT Manager** is responsible for implementing the policy.
- **ISMS manager** is responsible for updating, reviewing, and maintaining this policy.

Policy

Langate Group policy requires that:

- Data must be handled and protected according to its classification requirements and approved encryption standards.
- Whenever possible, data of the same classification to be stored in a given repository. Mixing sensitive and non-sensitive data in the same repository will be avoided.
- Security controls, including authentication, authorization, data encryption, and auditing, must be applied according to the highest data classification in a repository.
- Employees, contractors, and third-party users must not have direct administrative access to customers' production data during normal business operations, except in emergencies such as forensic analysis and manual disaster recovery.
- Services that are not required for the business purpose or function of the system must be disabled on all Production Systems.
- All access to Production Systems will be logged.
- Security monitoring, including activity and file integrity monitoring, vulnerability scanning, and malware detection, will be enabled on all Production Systems.

Data Protection Implementation and Processes

Customer Data Protection

Unless requested otherwise, Langate Group will host customer data on **Microsoft Azure** in the **East US** region when needed.

Langate Group will adhere to the following processes to reduce the risk of compromising Production Data:

- Controls designed to protect Production Data from improper alteration or destruction will be implemented and reviewed.
- Confidential data will be stored to support user access logs and automated monitoring for potential security incidents.
- Langate Group Customer Production Data will be segmented and only accessible to authorized customers and users.
- All customer production data at rest will be stored in encrypted volumes using encryption keys managed by Langate Group.
- Volume encryption keys and machines that generate them will be protected from unauthorized access. Key material will only be accessible by privileged accounts.

Access

- Access to production systems for Langate Group employees, contractors, and third-party users will be guarded by an approval process and will be disabled by default.
- When access is approved, temporary access will be granted. Production access will be reviewed by the security team on a case-by-case basis.

Separation

Where appropriate, Langate Group will follow these processes for Customer Data separation:

- Customer data will be logically separated at the database/datastore level using a unique identifier for the customer.
- Separation will be enforced at the API layer, where the client must authenticate with a chosen account. The customer unique identifier will be included in the access token and used by the API to restrict data access to the account.

Monitoring

- Langate Group will monitor and control the operation of services. In case of system failure, key personnel will be notified by text, chat, and/or email to take corrective action.

Data At Rest

Encryption

All databases, data stores, and file systems are encrypted according to Langate Group's *Encryption Policy*.

Retention

Stored data will be categorized, and a retention schedule will be applied according to the *Asset Management Policy*, *Data Classification Policy*, and *Data Retention Policy*. Considerations for retention timeframe include:

- Statutory, regulatory, or contractual requirements
- Type of data (e.g., accounting records, database records, audit logs)

- Type of storage media (e.g., paper, hard drive, server)

Storage and Disposal

Customer data must be appropriately stored and handled while at rest. Handling of data stored at rest will comply with provisions of the *Asset Management Policy*, *Data Classification Policy*, and *Data Retention Policy* and will include:

- Authorization to access or manage stored data
- Proper identification of records and their retention period
- Technology change and the ability to access data throughout the retention period
- Acceptable timeframe and format to retrieve data
- Appropriate methods of disposal

Data Deletion

Stored Customer data that is no longer required will be deleted in accordance with Langate Group's business objectives, applicable laws and regulations, and relevant third-party agreements. A record of such deletion will be kept.

The following methods will be used to delete data:

- Overwriting
- Physical Destruction
- Secure Erase
- Shredding

Data in Transit

Necessity

Data will only be transferred where strictly necessary for effective business processes.

Transfer Factors

Before choosing the method of data transfer, the following will be considered:

- Nature, sensitivity, confidentiality, and value of the information
- Size of data being transferred
- Impact of loss during transit

Encryption

To ensure the safety of data in transit:

- All external data transmission will be encrypted end-to-end using PKI with server encryption keys managed by Langate Group. This includes, but is not limited to, cloud infrastructure and third-party vendors and applications.
- All internet and intranet connections will be encrypted using PKI and authenticated using a strong protocol, a strong key exchange, and a strong cipher.

Information Exchange

Information will be exchanged between Langate Group's system and other information systems only as authorized by legal agreements and/or NDAs and BAAs, which include:

- Interface characteristics;
- Security and privacy requirements, controls, and responsibilities for each system/organization; and,

- Impact level of the information communicated.

The agreement(s) will be reviewed and updated as needed.

End-user Messaging Channels

- Restricted and sensitive data must not be sent over electronic end-user messaging channels such as email or chat unless end-to-end encryption is enabled.
- Messages must be protected from unauthorized access, modification, or denial of service commensurate with the classification scheme adopted by the organization.
- Messages must be reviewed prior to sending to ensure correct addressing and transportation.
- The reliability and availability of the messaging channel must be verified.
- All applicable legal requirements must be adhered to.
- Use of external public services such as instant messaging, social networking, or file sharing will require prior approval and authorization.
- Publicly accessible networks must be controlled by stronger authentication.

Event Logs

- All Langate Group systems that handle confidential information, accept network connections, or make access control (authentication and authorization) decisions will record and retain audit-logging information sufficient to answer: What activity was performed? Who performed it? Where, when, and how (with what tools) was it performed? And what was the status, outcome, or result of the activity?

Logged Activities

The logs will be created whenever the system is asked to perform any of the following activities:

- Create, read, update, or delete confidential information, including confidential authentication information such as passwords;
- Initiate a network connection;
- Accept a network connection;
- User authentication and authorization for activities covered above, such as user login and logout;
- Grant, modify, or revoke access rights, including adding a new user or group, changing user privilege levels, changing file permissions, changing database object permissions, changing firewall rules, and user password changes;
- System, network, or services configuration changes, including installation of software patches and updates or other installed software changes;
- Application process startup, shutdown, or restart;
- Application process abort, failure, or abnormal end, especially due to resource exhaustion or reaching a resource limit or threshold (such as for CPU, memory, network connections, network bandwidth, disk space, or other resources), the failure of network services such as DHCP or DNS, or hardware fault; and
- Detection of suspicious/malicious activity such as from an Intrusion Detection or Prevention System (IDS/IPS), anti-virus system, or anti-spyware system.

Log Elements

Each log will identify or contain at least the following elements, directly or indirectly (unambiguously inferred):

- Type of action – examples include authorize, create, read, update, delete, and accept network connection.
- Subsystem performing the action – examples include process or transaction name, process or transaction identifier.
- Identifiers (as many as available) for the subject requesting the action – examples include user name, computer name, IP address, and MAC address.
 - In the case of sharing logs with third parties (including auditors), the use of identifiers containing PII in the log(s) will be limited.

- Identifiers (as many as available) for the object the action was performed on – examples include file names accessed, unique identifiers of records accessed in a database, query parameters used to determine records accessed in a database, computer name, IP address, and MAC address.
- Before and after values when action involves updating a data element, if feasible.
- Date and time the action was performed, including relevant time-zone information if not in Coordinated Universal Time.
- Whether the action was allowed or denied by access-control mechanisms.
- Description and/or reason-codes of why the action was denied by the access-control mechanism, if applicable.

Formatting, Storage, Clock Synchronization

- The system will support the formatting and storage of audit logs in such a way as to ensure the integrity of the logs and to support enterprise-level analysis and reporting.
- The system will also ensure clock synchronization for the accuracy of audit logs. A network time protocol will be used to keep all the servers synchronized with the public time servers.

Administrators and Operator Logs

To safeguard and prevent manipulation of logs by privileged users, the following will be implemented where appropriate and possible:

- System administrators are not permitted to erase or deactivate logs of their own activities.
- Real-time copying of logs to a system outside the control of a system administrator or operator will be implemented.
- Monitoring system and network administration activities using an intrusion detection system managed outside the control of system and network administrators will be conducted.
- Logs will be frequently reviewed to maintain the accountability of privileged users.

Data De-identification/Masking

Langate Group will determine types of sensitive data that require de-identification/masking as outlined in the Data Classification Policy.

For sensitive data de-identification, Langate Group will use the following techniques:

- **Redaction:** Erasing or expunging sensitive data from a record.
- **Suppression:** Removing data (e.g., from a cell or row in a table, or data element(s) in a record) prior to dissemination to prevent the identification of individuals in small groups or those with unique characteristics.
- **Blurring:** Reducing data precision by combining one or more data elements.
- **Masking:** Replacing one data element with either a random or made-up value or with another value in the data set.

The adequate de-identification will be verified to ensure that no connection to sensitive data remains.

Data Loss Prevention (DLP)

- DLP measures will be implemented to prevent unauthorized data access, transfer, or leakage.
- The Data Classification Policy will be referenced to ensure data is handled according to its classification level.
- Data transfers will be monitored and controlled to detect and prevent potential data breaches.
- DLP tools will be used to enforce data protection policies and ensure compliance with regulatory requirements.
- DLP measures will be regularly reviewed and updated to address emerging threats and vulnerabilities.

Confidentiality/Non-Disclosure Agreements (NDA)

Langate Group uses confidentiality or non-disclosure agreements to protect confidential information using legally enforceable terms. NDAs are applicable to both internal and external parties. NDAs will have the following elements:

- Definition of the information to be protected
- Duration of the agreement
- Required actions upon termination of the agreement
- Responsibilities and actions to avoid unauthorized disclosure
- Ownership of information, trade secrets, and intellectual property
- Permitted use of the confidential information and rights to use information
- Audit and monitor activities involving confidential information
- Process of notification and reporting of unauthorized disclosure or information leakage
- Information return or destruction terms when the agreement is terminated
- Actions in case of breach of agreement
- Periodic review

Policy version history

 Policy details

Policy name	Renewal date
Data Protection Policy	September 26, 2026
Description	
The Data Protection policy outlines many of the procedures and technical controls in support of data protection.	

 Version history

Version 1					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
July 15, 2024	April 17, 2025	April 17, 2025	Eugene Skubach	Eugene Skubach	Eugene Skubach
Version 1.1					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
May 6, 2025	No approval required	May 6, 2025	Eugene Skubach	-	Eugene Skubach
Version 1.2					
Explanation of changes					
'Revision History' section has been removed					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
September 26, 2025	No approval required	September 26, 2025	Eugene Skubach	-	Eugene Skubach